

Sections 13–14: Threat Hunting & Dashboards

13. Threat Hunting Exercises (20)

Threat hunting differs from detection engineering: you're not waiting for a rule to fire — you're proactively querying data on a hypothesis ("if an attacker did X, what would it look like in my logs?"). Each exercise below gives the hypothesis, the MITRE technique, and a query (KQL for Kibana/Wazuh dashboard, or a Sigma rule where the query needs vendor translation).

#	Hypothesis	MITRE	Query (Kibana KQL unless noted)
1	A process is spawning from an unusual parent (e.g., Office spawning a shell)	T1566, T1059	<code>event.code:1 and process.parent.name:("winword.exe" or "excel.exe") and process.name:("powershell.exe" or "cmd.exe")</code>
2	Rare processes never seen before on this host in the last 30 days	T1204	Aggregation: <code>process.name</code> cardinality over 30d, filter count = 1
3	LOLBins (living-off-the-land binaries) making network connections	T1218	<code>event.code:3 and process.name:("certutil.exe" or "mshta.exe" or "regsvr32.exe" or "rundll32.exe")</code>
4	Processes running from unusual paths (Temp, AppData, ProgramData)	T1036	<code>event.code:1 and process.executable:(*\\Temp* or *\\AppData* or *\\ProgramData*)</code>

#	Hypothesis	MITRE	Query (Kibana KQL unless noted)
5	Unsigned binaries executing	T1553.002	<code>event.code:1 and process.pe.company:"" (empty company = unsigned in Sysmon 7-augmented data)</code>
6	Outbound connections to rare/first-seen external IPs	T1071	<code>event.code:3 and destination.ip:*</code> — pivot on destination.ip cardinality, isolate singletons
7	Beaconing pattern — regular-interval connections to the same destination	T1071	Group by <code>destination.ip</code> , histogram of <code>@timestamp</code> deltas — look for low-variance intervals
8	Accounts logging in from two geographically implausible locations within a short window ("impossible travel")	T1078	<code>event.code:4624</code> grouped by <code>user.name</code> , compare <code>source.ip</code> diversity over 1h windows
9	Service accounts performing interactive logons (LogonType 2/10)	T1078.002	<code>event.code:4624</code> and <code>user.name:svc_*</code> and <code>winlog.logon.type:(2 or 10)</code>
10	New autorun/Run-key registry entries across the fleet	T1547.001	<code>event.code:13</code> and <code>registry.path:*\\CurrentVersion\\Run*</code>

#	Hypothesis	MITRE	Query (Kibana KQL unless noted)
11	PsExec / remote service creation patterns (lateral movement)	T1021.002	<code>event.code:1 and process.name:"ps exec.exe" or Event ID 7045 with ImagePath containing \\ADMIN\$\\</code>
12	WMI-based remote execution	T1047	<code>event.code:1 and process.parent.name:"WmiPrvSE.exe"</code>
13	Kerberoasting indicators (abnormal volume of TGS requests)	T1558.003	Windows Event ID 4769 grouped by <code>user.name</code> , count > baseline
14	DNS queries with high entropy / long labels	T1071.004	Zeek <code>dns.log: query:/^[a-zA-Z0-9]{40,}\./</code>
15	Archive/compression utility execution followed by outbound connection (staging + exfil)	T1560, T1041	<code>event.code:1 and process.name:("7z.exe" or "rar.exe" or "tar")</code> correlated with <code>event.code:3</code> on same host within 5 min
16	Clearing of event logs (anti-forensics)	T1070.001	<code>event.code:1102</code> (Security log cleared) — should be zero occurrences in a healthy baseline; any hit is high-priority
17	Processes accessing browser credential stores	T1555.003	<code>event.code:11 and file.path:*\\Log</code>

#	Hypothesis	MITRE	Query (Kibana KQL unless noted)
			<code>in Data*</code> (Chrome) or <code>*\\logins.json*</code> (Firefox)
18	Scheduled tasks with suspicious triggers (logon-triggered, running from Temp)	T1053.005	Sigma rule against Event ID 4698, <code>TaskContent</code> regex on `%TEMP%
19	SSH logins using keys never seen before on that host	T1098.004	<code>auth.log</code> grep for new <code>key fingerprint</code> values not in <code>~/.ssh/authorized_keys</code> baseline
20	Sudden spike in failed logon volume across multiple accounts (spray, not brute force)	T1110.003	<code>event.code:4625</code> grouped by <code>source.ip</code> , count distinct <code>user.name</code> > 5 within 10 min

How to run these in practice: Wazuh's dashboard has a **Discover** panel (KQL-compatible query bar) — paste the query pattern, adjust time range, save as a saved search once validated. For exercises needing aggregation (8, 10, 15, 20), build a Kibana **Lens** visualization instead of relying on the raw query bar.

13.1 Bonus: Perimeter Threat Hunting (Sophos — new, not counted in the core 20 above)

Kept separate from the numbered 20 so every place in this repo that cites "20 threat hunting exercises" (README, resume bullets) stays accurate — treat these as an optional extension once the perimeter layer ([08-Sophos-Firewall-Integration.md](#)) is live.

#	Hypothesis	MITRE	Query
B1	An external IP has both a Sophos	T1595.001	<code>rule.groups:sophos</code> AND

#	Hypothesis	MITRE	Query
	deny-burst and a MISP hit — correlating perimeter noise against threat intel, not just endpoint IOCs		<code>rule.id: 110110</code> joined against MISP-enriched alerts on the same <code>srcip</code> — build as a Kibana Lens table grouped by <code>srcip</code> , not a single query bar search
B2	A source IP that failed Sophos WebAdmin auth later succeeds on an <i>endpoint</i> login — perimeter brute force followed by an actual foothold	T1110 → T1078	Sequential correlation: <code>rule.id: 110106</code> (Sophos auth fail) then <code>event.code: 4624</code> for the same <code>srcip</code> within the following hour
B3	Firewall rule changes made outside a documented change window (a compromised admin account modifying Sophos rules to open access)	T1562.004 (Impair Defenses: Disable/Modify Firewall)	Sophos audit/admin-event logs (<code>log_component: "Firewall Rule"</code> combined with an admin-action subtype, not traffic) — confirm the exact subtype via <code>wazuh-logtest</code> on your own captured admin-change log before building this as a saved search, same caveat as detection 10.20

14. SOC Dashboards

Build these as separate Kibana dashboards (or Wazuh custom dashboard tiles) once real alert data exists — don't build against empty indices, the panels will be meaningless placeholders.

14.1 Authentication Dashboard

- Panel: Failed vs. successful logons over time (stacked area, `event.code:4624` vs `4625`)
- Panel: Top 10 accounts by failed logon count (bar)
- Panel: Logon type breakdown (pie — interactive/network/RDP/service)
- Panel: Geo-map of source IPs for external-facing auth (if applicable)

14.2 Threats/Alerts Dashboard

- Panel: Alert count by severity level (0-15) over time
- Panel: Top MITRE ATT&CK tactics triggered (bar, from `rule.mitre.tactic`)
- Panel: Alert count by agent/host (identifies your "hottest" endpoint)
- Panel: MISP-enriched alerts vs. total alerts (ratio — shows enrichment coverage)

14.3 Malware/Process Dashboard

- Panel: Process creation volume over time
- Panel: Top parent-child process pairs (table) — flags anomalies fast
- Panel: Unsigned process execution count
- Panel: Known-malicious hash hits (from MISP integration)

14.4 Network Traffic Dashboard

- Panel: Top talkers (source/destination IP pairs by byte volume, from Zeek `conn.log`)
- Panel: Suricata alerts by signature category
- Panel: DNS query volume by domain (top 20)
- Panel: Geolocation map of external destination IPs (MaxMind GeoIP, bundled with many Suricata/Zeek setups)

14.7 Perimeter Dashboard (Sophos — new)

- Panel: Auth failures by target account (`rule.id: 110106`, bar chart)
- Panel: Deny-burst events over time (`rule.id: 110110`) — expect a baseline of internet background noise on the WAN side; this panel is most useful once you've tuned it per `06-Tuning-IR-Documentation.md` §15.2's Sophos-specific example, otherwise it's just showing you the internet exists
- Panel: Allow vs. Deny ratio by firewall rule (table — a rule with a very high deny ratio may be miscategorized traffic, worth reviewing even outside an incident)

- Panel: Top external source IPs by total perimeter events (cross-reference against MISP per hunting exercise B1 above)

14.5 Windows Events Dashboard

- Panel: Event ID frequency breakdown (Sysmon 1/3/10/11/13 distribution)
- Panel: New service/scheduled task timeline

14.6 Linux Events Dashboard

- Panel: SSH auth success/fail over time
- Panel: Sudo usage by user
- Panel: Auditd `identity_change` events timeline

Design note: every panel should answer a specific analyst question, not just "look impressive." If a panel doesn't help you decide "investigate further" or "ignore," cut it — dashboard sprawl is a documented real-world SOC problem, and demonstrating that judgment in your report is itself a signal of maturity.

Continue to: [06-Tuning-IR-Documentation.md](#)